Practical - 10

Practical Title: Secure Login/Logout with Sessions, Role-Based Access, Timeout, and Remember-Me Token

Problem Definition: Develop secure login and logout functionality using PHP sessions. Verify password using password_verify(), regenerate session ID after login, restrict dashboard access, implement role-based redirection, session timeout, and optional secure remember-me token.

Theory :

1. Are sessions started and destroyed securely?

Yes. session_start() is called at the top of every protected page, and session_regenerate_id(true) is used after a successful login to prevent session fixation. On logout, session_unset() and session_destroy() are used, the session cookie is deleted, and the user is redirected to the login page.

2. Is password_verify() used correctly?

Yes. The user is found by email using a prepared statement, and the entered password is compared with the stored hash using password_verify(). Passwords or hashes are never compared directly using ==, and a general message "Invalid email or password" is shown on failure.

3. Is unauthorized dashboard access blocked?

Yes. Every dashboard page checks whether $_SESSION['user_id'] is set. If the user is not logged in, the user is redirected to the login page and exit() stops the remaining code from running.

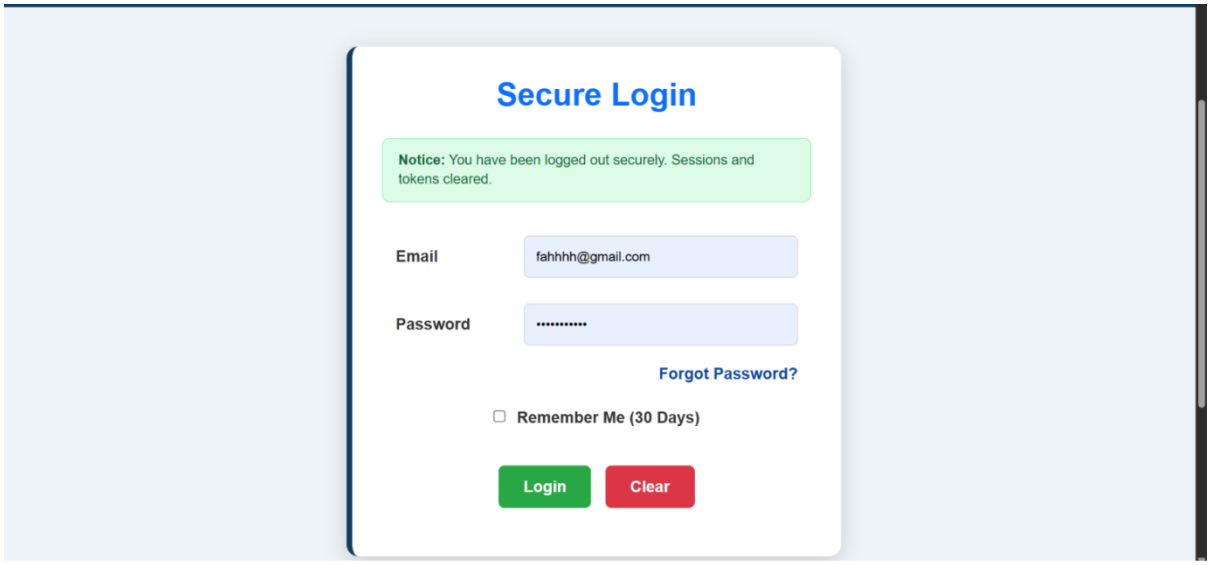
4. Is session timeout implemented?

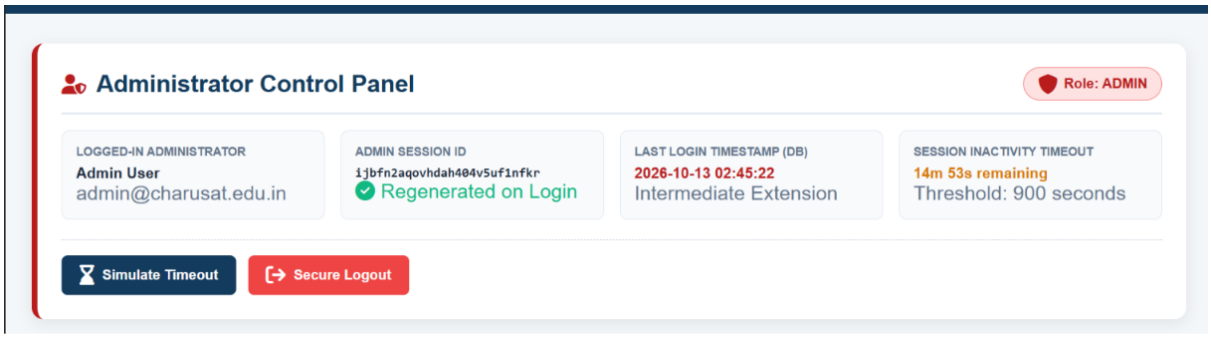
Yes. The time of the last activity is saved in $_SESSION['last_activity']. On every request, if the difference between the current time and the last activity is more than the allowed time (for example 30 minutes), the session is destroyed and the user is redirected to the login page with a timeout message.

5. Are admin and student users redirected to appropriate dashboards?

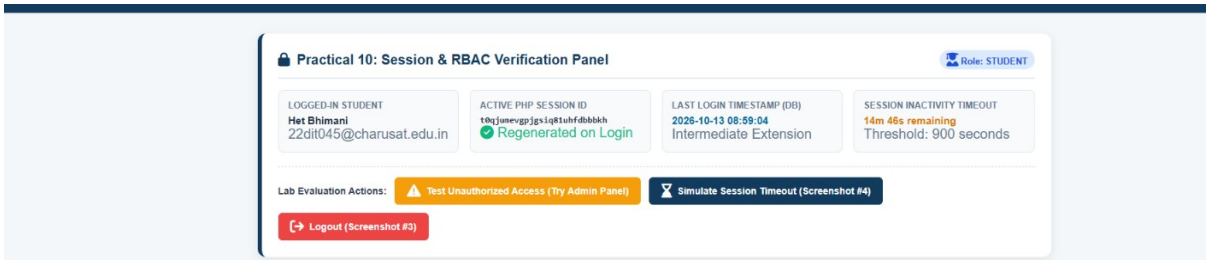
Yes. The role of the user is stored in the session after login. Admin users are redirected to the admin dashboard and student users are redirected to the student dashboard. Admin pages also check that the role is admin, so a student cannot open them.

Implementation/ Output/Result

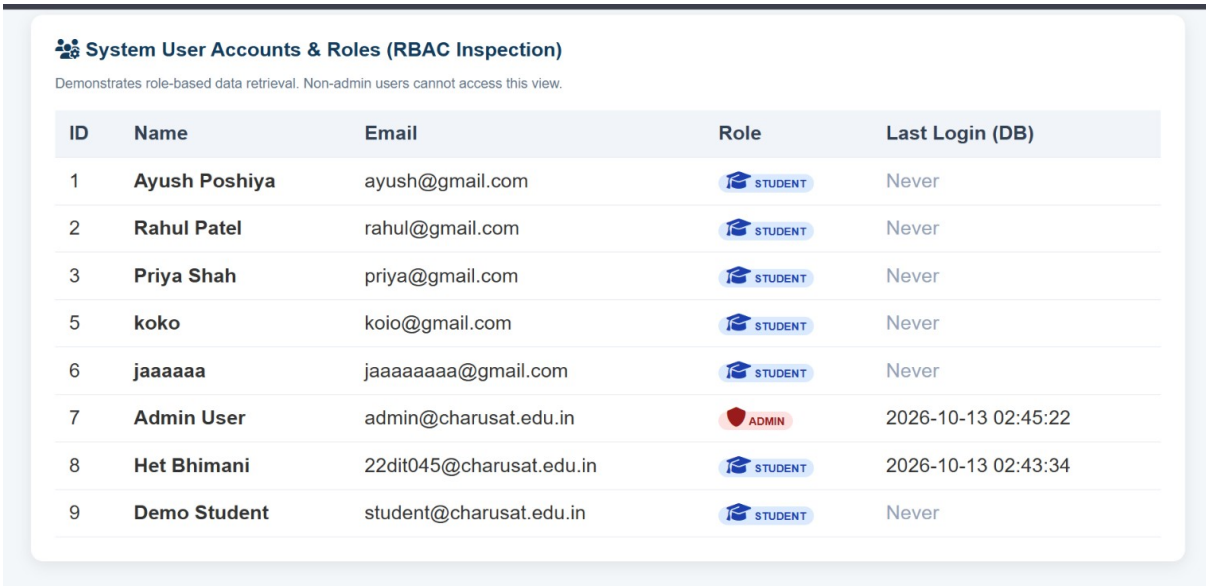




(Admin Role)



(Student Role)



System User Accounts & Roles (RBAC Inspection)

Demonstrates role-based data retrieval. Non-admin users cannot access this view.

ID	Name	Email	Role	Last Login (DB)
1	Ayush Poshiya	ayush@gmail.com	STUDENT	Never
2	Rahul Patel	rahul@gmail.com	STUDENT	Never
3	Priya Shah	priya@gmail.com	STUDENT	Never
5	koko	koio@gmail.com	STUDENT	Never
6	jaaaaaa	jaaaaaaaa@gmail.com	STUDENT	Never
7	Admin User	admin@charusat.edu.in	ADMIN	2026-10-13 02:45:22
8	Het Bhimani	22dit045@charusat.edu.in	STUDENT	2026-10-13 02:43:34
9	Demo Student	student@charusat.edu.in	STUDENT	Never

GitHub Repository Link:

https://github.com/ayushposhiya00-lab/Student-Hub/tree/main/Practical-10

Learning Outcomes:

- Understand how PHP sessions and cookies are used for authentication.
- Verify passwords securely using password_verify().
- Protect pages using session checks and role-based access control.
- Implement session timeout and secure logout.
- Redirect users to different dashboards based on their role.

Faculty Remarks: (Keep this blank for faculty)